
Livrable bêta — Jalon 5

Storybook Kids — Développement, tests, sécurité

Étudiant FORTUNATO Axel

Formation IPSSI — CDA Bachelor Fullstack DevOps

Promotion 2025–2026

Date Mai 2026

Table des matières

Jalon 5 — Version bêta Storybook Kids	2
1. Périmètre livré	2
Phase A — MVP (P1)	2
Phase B — TTS (F6)	2
Phase C — Favoris & progression (F4)	3
Phase D — Qualité (jalón 5)	3
2. Synthèse par rapport au CDCF (jalón 1)	3
3. Stack technique	4
4. Écarts assumés (CDCF / conception)	4
5. Sécurité — rappel OWASP	5
6. Phase D.4 — Revue sécurité et checklist qualité	6
6.1 Checklist code-standard.md §15 (état bêta)	6
6.2 Contrôles complémentaires (hors §15)	7
6.3 Limites connues (non bloquantes jalón 5)	7
7. Commandes qualité (local)	8
8. Scénario de démo (5–8 min)	8
Parent (parent@demo.local / parent123)	8
Admin (admin@demo.local / admin123)	8
Prérequis démo	8
9. Prochaine étape (jalón 6)	9

Jalon 5 — Version bêta Storybook Kids

Document de clôture du **développement bêta** (CDA fil rouge). Il complète le CDCF (jalón 1), l'UI/UX (jalón 2), la BDD (jalón 3) et la conception technique (jalón 4).

Dépôt : https://github.com/FortAxel/ipssi_project

Commit : feat: deliver milestone 5 beta storybook kids application

1. Périmètre livré

Phase A — MVP (P1)

Fonctionnalité	Statut	Détail
F1 Auth	Livré	Inscription, connexion JWT, profil (consultation)
F2 Catalogue	Livré	Liste + détail ; recherche/filtre côté API (UI catalogue sans filtre)
F3 Lecture	Livré	Pages, navigation, indicateur X/Y
F5 Admin	Livré	CRUD histoires/pages, statuts, upload images, gestion utilisateurs

Phase B — TTS (F6)

Élément	Statut
API POST /api/tts/synthesize	Livré
Provider	Microsoft Edge TTS (gratuit, sans clé API, CLI edge-tts dans Docker)
Configuration	Variables TTS_* (voir README racine du dépôt)
Secours navigateur	Web Speech API si TTS API désactivée

Phase C — Favoris & progression (F4)

Élément	Statut
Favoris (toggle + page dédiée)	Livré
Reprise de lecture	Livré (last_page_number)
Historique	Livré — onglet Profil → Historique (tableau : titre, progression, début, dernière lecture)
Schéma	last_page_number, started_at, last_read_at, is_completed reading_progress

Phase D — Qualité (jalon 5)

Élément	Statut
Lint PHP (PHP-CS-Fixer)	composer lint:php
Lint front (ESLint)	npm run lint
Tests PHPUnit	composer test (unitaire ReadingProgress + WebTestCase health)
Tests Vitest	npm test (libellés FR / i18n)
CI GitHub Actions	.github/workflows/ci.yml
Revue sécurité + checklist	Section 6 ci-dessous

2. Synthèse par rapport au CDCF (jalon 1)

Critère CDCF (§6)	Bêta
Fonctionnalités P1 (F1, F2, F3, F5)	Implémentées et démontrables

Critère CDCF (§6)	Bêta
Fonctionnalités P2 (F4, F6)	Livrées ; choix TTS = Edge (voir écarts §4)
Modes lecture parent / enfant / audio	Support visuel + lecture enfant + bouton Écouter (TTS)
Docker + MySQL + API REST + React	En place
CI GitHub Actions	En place
Tests automatisés	Présents (périmètre minimal documenté §4)
OWASP / sécurité de base	Revue §5–6
Responsive	Maquettes jalon 2 implémentées (desktop + mobile)
RGPD complet	Hors bêta (jalon 6 si requis)

3. Stack technique

Couche	Technologie
API	Symfony 7.2, PHP 8.2+, JWT (Lexik)
Données	MySQL 8, Doctrine ORM, migrations
Front	React 19, TypeScript, Vite
Conteneurs	Docker Compose (PHP-FPM, Nginx, MySQL, phpMyAdmin)
TTS externe	Microsoft Edge TTS (edge-tts dans l'image PHP)
Qualité	PHP-CS-Fixer, ESLint, PHPUnit, Vitest, GitHub Actions

Contenu de démo : **5 histoires** en français (backend/data/stories/), comptes fixtures documentés dans le README racine.

4. Écarts assumés (CDCF / conception)

Sujet	Choix bêta
TTS CDCF (Google / Polly / Web Speech)	Edge TTS documenté comme API externe gratuite
Historique F4	Liste dans le profil (pas d'écran catalogue « déjà lues » séparé)
Profil F1	Affichage seul (pas de modification e-mail / mot de passe)
F2 filtre / recherche	Paramètres API search et category ; pas encore de champs sur l'UI catalogue
RGPD	Pas de suppression de compte ni politique de confidentialité intégrée (hors périmètre bêta)
MPD jalon 3	reading_progress simplifié (last_page_number au lieu de current_page_id) — migration Version20260522140000
UML jalon 4	Séquences TTS avec text + /api/tts/synthesize (pas pageId seul)
Tests CDCF (Jest + RTL)	Vitest retenu côté front (équivalent moderne)
Tests API fonctionnels	GET /api/health couvert ; auth / catalogue / favoris : renforcement prévu post-bêta
CSRF Symfony (CDCF)	API stateless JWT : pas de formulaires Twig ; risque CSRF classique non applicable aux routes JSON

5. Sécurité — rappel OWASP

Mesures en place pour la bêta :

Risque / thème	Mesure
Injection SQL	Doctrine ORM, requêtes paramétrées
XSS	Échappement React ; pas de dangerouslySetInnerHTML sur le contenu des histoires
Authentification	JWT, mots de passe hachés (algorithme Symfony par défaut)

Risque / thème	Mesure
Autorisation	ROLE_USER / ROLE_ADMIN ; routes /api/admin/* réservées admin
Fuite de données entre utilisateurs	Progression et favoris liés au user_id du token
Secrets	Clés JWT et .env.local hors dépôt ; variables Docker pour la BDD
CORS	CORS_ALLOW_ORIGIN (Nelmio) limité aux origines dev
Upload fichiers	Types MIME autorisés, taille max 5 Mo, noms aléatoires, dossier dédié
TTS	Pas de stockage du texte utilisateur hors flux lecture ; pas de clé API tierce payante

Note CSRF : le CDCF mentionne les tokens CSRF Symfony ; ils s'appliquent aux formulaires web classiques. Ici l'API est consommée en **SPA + Bearer token** ; la protection repose sur le JWT et le CORS, pas sur un token CSRF par requête.

6. Phase D.4 — Revue sécurité et checklist qualité

Le plan de développement (PLAN-DEV-BETA, phase **D.4**) demande deux choses distinctes :

1. **Revue OWASP** — vérifier que les risques courants sont traités (section 5 ci-dessus).
2. **Checklist avant merge** — reprendre la liste du document docs/code-standard.md, §15, et indiquer ce qui est validé pour la **clôture du jalon 5** (pas seulement « en cours de dev »).

Cette section remplit explicitement le point D.4 pour le livrable PDF.

6.1 Checklist code-standard.md §15 (état bêta)

Point	Statut	
	bêta	Commentaire
Nommage conforme (fichiers + identifiants)	Validé	Anglais en code, FR en UI (frontend/src/i18n/fr.ts)
Pas de secret ni de console.log de debug	Validé	JWT dans config/jwt/*.pem (gitignore); pas de clé API TTS payante
PHPDoc / TSDoc sur les API publiques ajoutées	Validé	Services, controllers et DTO principaux documentés
Texte UI en français via fichiers i18n	Validé	labels centralisés
lint / PHP-CS-Fixer dry-run OK	Validé	composer lint:php; CI
Tests ajoutés ou mis à jour pour la logique touchée	Validé	PHPUnit + Vitest (périmètre minimal, voir §4)
Migration Doctrine si schéma change	Validé	Migrations versionnées (dont F4 et reading_progress enrichi)

6.2 Contrôles complémentaires (hors §15)

Contrôle	Statut
Isolation des données utilisateur (progression, favoris)	Validé
Routes admin inaccessibles au compte parent	Validé
Pipeline CI verte sur la branche de livraison	À vérifier sur GitHub après push
Démo reproductible depuis le README	Validé (Docker + fixtures)

6.3 Limites connues (non bloquantes jalon 5)

- Pas d'audit RGPD formel (export / suppression compte).
- Pas de tests API sur auth, favoris ou progression (renforcement possible).
- Pas de scan automatique OWASP (ZAP) dans la CI — revue manuelle documentée ici.

7. Commandes qualité (local)

```
# Backend (dans backend/)
composer lint:php          # vérification style
composer lint:php:fix      # correction automatique
composer test              # PHPUnit (clés JWT requises : voir README racine)

docker compose exec php composer lint:php  # si conteneur démarré

# Frontend (dans frontend/)
npm run lint
npm test
npm run build
```

CI : chaque push/PR sur main ou develop déclenche le workflow **CI** (lint + tests + build front).

8. Scénario de démo (5–8 min)

Parent (parent@demo.local / parent123)

1. Connexion → **Catalogue** (5 histoires, anneau de progression si déjà lu).
2. Ouvrir une histoire → lecture page par page → **Écouter** (TTS si Docker avec TTS_ENABLED=1).
3. Fermer / revenir → reprise à la dernière page.
4. Ajouter un **favori** (cœur) → menu **Favoris**.
5. **Profil** → **Historique** : tableau des lectures.

Admin (admin@demo.local / admin123)

1. **Administration** → nouvelle histoire (titre, description, **upload couverture**, statut PUBLISHED).
2. **Gérer les pages** → ajout texte + illustration.
3. Vérifier l'histoire dans le catalogue parent.

Prérequis démo

```
docker compose up -d --build  
cd frontend && npm install && npm run dev
```

API : http ://127.0.0.1 :8088 — Front : http ://127.0.0.1 :5173

9. Prochaine étape (jalón 6)

- Déploiement (hébergement, HTTPS, variables de prod).
 - Durcissement RGPD (export / suppression compte) si requis.
 - Tests API élargis (auth, favoris) et éventuel scan sécurité automatisé.
-

Références : CDCF docs/jalon-1-cdcf/cdcf-fr.md — Plan interne PLAN-DEV-BETA.md (phases A à D) — Conventions docs/code-standard.md.